Based on the comprehensive research gathered, I'll now create the structured regulatory documentation.

FINTECH COMPLIANCE & DIGITAL PAYMENT PROCESS EXPLAINER SYSTEM

Structured Regulatory Research Documentation

SECTION 1: RBI DIGITAL PAYMENT SYSTEM GUIDELINES

1.1 Overview of RBI Payment System Framework

The Reserve Bank of India (RBI) regulates and supervises payment and settlement systems in India under the Payment and Settlement Systems Act, 2007 (PSS Act). This framework establishes a comprehensive regulatory architecture governing all digital payment transactions, ensuring safety, security, efficiency, and accessibility.

Key Framework Components:

- Central authority for authorization and supervision of payment systems
- Risk management and oversight mechanisms
- Consumer protection provisions
- Settlement finality guarantees
- Fraud prevention and cybersecurity requirements

Source:

- Payment and Settlement Systems Act, 2007 (enacted by Indian Parliament)
- RBI Department of Payment & Settlement Systems (DPSS) regulatory framework

Reference:

https://www.ahlawatassociates.com/blog/the-payment-and-settlement-systems-act-2007-and-rbis-regulatory-powers

---

1.2 Legal Foundation (Acts, Regulations)

Primary Legislation:

Payment and Settlement Systems Act, 2007 (PSS Act, 2007)

- Grants RBI statutory authority to regulate and oversee payment systems
- Provides legal recognition to payment systems
- Establishes finality of settlement under Section 23
- Empowers RBI to issue directions and regulations

Supporting Regulations:

- Banking Regulation Act, 1949: Governs banks participating in payment systems
- Reserve Bank of India Act, 1934: Establishes RBI's constitutional authority
- Prevention of Money Laundering Act (PMLA), 2002: Mandates AML/KYC compliance for payment entities
- Information Technology Act, 2000: Governs electronic authentication and digital signatures
- Indian Contract Act, 1872: Governs contractual obligations between parties in payment transactions

Key Provisions of PSS Act, 2007:

- Section 4: Authorization requirement for payment systems
- Section 18: Power to issue directions to system providers and participants
- Section 23: Finality and irrevocability of settlement
- Section 26: Payment system data preservation requirements (10 years)
- Section 30: Penalty provisions for non-compliance

Reference:

- PSS Act, 2007 (Government of India legislation)
- RBI regulatory framework publications

1.3 Role of RBI in Payment Regulation

Regulatory Functions:

1. Authorization & Licensing
    - Grant authorization to payment system operators (PSOs)
    - Approve participation of banks and non-banks in payment systems
    - License Payment Aggregators (PA-O, PA-P, PA-CB)
    - Authorize Prepaid Payment Instrument (PPI) issuers
2. Supervision & Oversight

    - Conduct audits and inspections of PSOs and participants
    - Monitor system performance, availability, and resilience
    - Review risk management frameworks
    - Assess compliance with regulatory guidelines
3. Policy Formulation
    - Issue Master Directions and circulars
    - Define operational guidelines and procedural standards
    - Set transaction limits and security requirements
    - Establish dispute resolution mechanisms
4. Settlement Infrastructure
    - Operate Real-Time Gross Settlement (RTGS) system
    - Facilitate multilateral net settlement through settlement accounts
    - Maintain settlement guarantee mechanisms
    - Ensure finality of settlement
5. Consumer Protection
    - Mandate grievance redressal frameworks
    - Enforce disclosure and transparency requirements
    - Implement fraud monitoring and reporting systems
    - Operate Banking Ombudsman Scheme for payment disputes
6. Innovation Enablement
    - Issue frameworks for emerging payment methods (BNPL, IoT payments)
    - Facilitate sandbox environments for fintech innovation
    - Promote interoperability across payment systems

Reference:

- RBI Department of Payment & Settlement Systems (DPSS)
- PSS Act, 2007, Sections 4, 7, 18, 26
- https://www.ahlawatassociates.com/blog/the-payment-and-settlement-systems-act-2007-and-rbis-regulatory-powers

---

1.4 Payment System Operators (PSOs)

Definition:

Payment System Operators (PSOs) are entities authorized by RBI under Section 4 of PSS Act, 2007 to operate payment systems in India.

Categories of PSOs:

1. Bank PSOs:

- Regulated under Banking Regulation Act, 1949

- Authorized for mobile banking services
- Examples: All scheduled commercial banks, RRBs, cooperative banks

2. Non-Bank PSOs:

- National Payments Corporation of India (NPCI): Operates UPI, IMPS, RuPay, NETC, NACH, CTS
- Clearing Corporation of India Ltd (CCIL): Settlement agency for forex and G-Sec transactions
- Payment Aggregators: PA-Online, PA-Physical, PA-Cross Border
- PPI Issuers: Wallet providers, card issuers

Regulatory Requirements for PSOs:

1. Authorization Process
    - Apply to RBI with technical, financial, and operational details
    - Demonstrate adequate risk management frameworks
    - Meet capital and net worth requirements
    - Obtain Board approval and Letter of Admission from RBI
2. Ongoing Compliance
    - Maintain 99.9% system uptime (excluding scheduled maintenance)
    - Conduct annual security audits by CISA-equivalent or PCI QSA auditors
    - Submit periodic reports to RBI (transaction data, incidents, settlement)
    - Maintain data security and business continuity plans
3. Oversight & Audit
    - RBI may conduct inspections at any time
    - PSOs must provide full access to systems and records
    - Annual internal audits mandatory
    - Compliance with ISO 27001, PCI-DSS standards
4. Termination/Suspension Conditions
    - License cancellation by RBI
    - Moratorium or winding up proceedings
    - Material breach of regulations
    - Repeated settlement defaults (>3 times/month)
    - RTGS membership suspension

Prior Approval Requirements (Non-Bank PSOs):

- Takeover or acquisition of control
- Change of management
- Sale/transfer of payment activity
- Mergers and amalgamations

Reference:

- PSS Act, 2007, Section 4

- UPI Procedural Guidelines, Version 1.5 (July 2016), Section 5
- https://www.taxmann.com/post/blog/non-bank-psos-required-to-take-prior-approval-for-takeover-acquisition-sale-transfer-of-payment-activity
- NEFT Procedural Guidelines (April 2011), Section 5

1.5 Settlement and Clearing Mechanisms

Definitions:

Clearing:

The process of transmitting, reconciling, and confirming payment instructions between participating institutions prior to settlement. Clearing establishes net or gross obligations between parties.

Settlement:

The actual discharge of obligations by transferring funds between settlement accounts maintained at the central bank (RBI).

Settlement Models:

1. Real-Time Gross Settlement (RTGS)

- Mechanism: Transaction-by-transaction settlement on gross basis
- Finality: Immediate and irrevocable upon completion
- Settlement Time: Continuous during operating hours (00:30 - 18:00 on weekdays; 00:30 - 14:00 on Saturdays)
- Credit Time: Within 30 minutes to beneficiary account
- Minimum Amount: No minimum (previously ₹2 lakh, removed)
- Settlement Location: RBI settlement accounts

2. Deferred Net Settlement (DNS)

- Mechanism: Multilateral netting of obligations, settled at batch intervals
- Systems Using DNS: NEFT, UPI (via IMPS settlement), Cheque Clearing
- Net Position Calculation: Credits minus debits = net receivable/payable
- Settlement: Via RTGS after net position determination

3. Real-Time Settlement (via IMPS infrastructure)

- Mechanism: Real-time settlement with Settlement Guarantee Mechanism (SGM)

- Systems Using: UPI, IMPS
- Net Debit Cap (NDC): Pre-funded limits assigned to each bank
- Settlement Refresh: After each settlement cycle

Settlement Cycles:

NEFT (National Electronic Funds Transfer):

- Cycle: Batch processing every 30 minutes (48 settlements per day)
- Operating Hours: 24x7x365 (since December 2019)
- Credit Obligation: Within 2 hours of batch settlement (B+2 discipline)
- Return Cycle: B+2 (must return within 2 hours if credit not possible)
- Settlement Method: Deferred Net Settlement via RTGS

UPI (Unified Payments Interface):

- Real-time Authorization: Immediate debit and credit authorization
- Settlement Infrastructure: IMPS settlement mechanism
- Settlement Guarantee: Yes, via IMPS SGM framework
- NDC Allocation: Percentage of bank's IMPS NDC limit
- Settlement Batches: Multiple per day (specific timings determined by NPCI)

IMPS (Immediate Payment Service):

- Settlement Type: Near real-time with SGM
- Cycle: Multiple settlements throughout the day
- Transaction Limit: ₹5 lakh per transaction (as of latest guidelines)

RTGS:

- Settlement: Transaction-by-transaction (gross settlement)
- No Batching: Continuous processing during operating hours

Cheque Clearing System (T+0 since October 4, 2025):

- Previous Model: T+1 batch processing
- Current Model: Continuous clearing throughout the day
- Settlement: Same-day credit (T+0)
- Processing: Via NPCI Centralised Clearing House (CCH)

Reference:

- NEFT Procedural Guidelines, Section 7 (Inter-Bank Settlement)
- UPI Procedural Guidelines, Annexure I (Settlement & Reports)
- https://www.slbcmadhyapradesh.in/docs/UPI_Procedural_Guidelines24_12_2016.pdf
- https://iibf.org.in/documents/MasterCirculars/General/3b.NEFT-161118.pdf

- https://www.angelone.in/news/market-updates/npcis-new-system-clears-rs-3-lakh-crore-in-continuous-cheque-processing

---

1.6 Risk Management & Oversight Mechanisms

1. Settlement Guarantee Mechanism (SGM)

Purpose: Ensures completion of settlement even if one or more participants default

Components:

- Net Debit Cap (NDC): Maximum net debit position allowed per participant
- Collateral Requirements: Cash/securities deposited with RBI
- Default Handling: Recalculation of settlement excluding defaulting participant
- Loss Mutualization: Shared loss allocation among non-defaulting participants

Default Triggers:

- Failure to meet settlement obligation
- Insufficient balance in RTGS settlement account
- Recalculation invoked >3 times per month = permanent default review

---

2. Operational Risk Management

System Availability Requirements:

- Uptime: 99.9% (excluding scheduled maintenance with 48-hour notice)
- Disaster Recovery: Business continuity plans mandatory
- Redundancy: Primary and backup infrastructure required

Security Requirements:

- Annual Audits: By CISA-equivalent or PCI QSA auditors
- Certifications: ISO 27001 (Information Security), PCI-DSS (for card systems)
- Incident Reporting: Monthly reports to RBI
- VAPT: Bi-annual Vulnerability Assessment and Penetration Testing

Data Protection:

- Encryption: End-to-end encryption for sensitive data (PIN, credentials)
- PKI Infrastructure: Public Key Infrastructure for secure credential transmission
- Storage: Minimum 10-year retention of transaction records (PSS Act, Section 26)

- Access Controls: Role-based access, audit trails maintained

---

3. Fraud Monitoring & Prevention

Transaction-Level Security:

- Two-Factor Authentication (2FA): Mandatory for all digital payment transactions
    - First Factor: Device fingerprint, mobile number, card
    - Second Factor: PIN, OTP, biometric (IRIS/fingerprint)
- Device Binding: Mobile device fingerprinting for app-based transactions
- Transaction Limits: Upper limits set by RBI (e.g., UPI: ₹1 lakh per transaction)

Monitoring Systems:

- Fraud Scoring: Real-time risk assessment by PSPs/payment gateways
- Behavioral Analytics: Pattern detection for unusual transactions
- Velocity Checks: Transaction frequency and amount monitoring
- Suspicious Transaction Reporting (STR): Mandatory reporting to FIU-IND

---

4. Dispute Resolution & Chargeback

Customer Complaint Process:

- First Point of Contact: Payment Service Provider (PSP) or originating bank
- TAT (Turnaround Time): Complaints resolved within defined timelines per operating guidelines
- Escalation: Banking Ombudsman if unresolved within 30 days

Failed Transaction Handling:

- Auto-Reversal: Failed transactions reversed immediately or within 5 working days
- Compensation: Current RBI LAF Repo Rate + 2% for delays attributable to bank negligence

Chargeback Process (for card transactions):

- Customer disputes transaction with issuing bank
- Issuing bank assigns reason code, initiates chargeback via card network
- Acquiring bank/Payment Aggregator notifies merchant
- Merchant responds within defined timeframe with evidence
- Issuing bank reviews and makes final determination

---

5. Supervisory Oversight

RBI Oversight Functions:

- Conduct on-site and off-site inspections of PSOs
- Review audit reports and compliance certificates
- Monitor system performance metrics (uptime, transaction success rates)
- Assess adequacy of risk management frameworks
- Impose penalties for violations (fines, suspension, license cancellation)

Steering Committees:

- UPI Steering Committee (quarterly meetings, IMPS + additional members)
- Payment System Advisory Council (PAC) as per Payments Vision 2025

Reference:

- UPI Procedural Guidelines, Section on Security Considerations
- NEFT Procedural Guidelines, Section 7 (Settlement and Default Handling)
- Master Direction - KYC (Know Your Customer) Direction, 2016
- PSS Act, 2007, Sections 18, 23, 26, 30
- https://www.lawrbit.com/article/master-direction-kyc-ensuring-financial-integrity-and-security/

SECTION 2: UPI & NPCI WORKFLOW DOCUMENTATION

2.1 UPI Architecture Overview

System Components:

1. National Payments Corporation of India (NPCI)

- Role: Central switch operator, network coordinator, settlement facilitator
- Functions: Message routing, address resolution (Aadhaar-based), settlement coordination
- Ownership: NPCI owns intellectual property rights to UPI network
- Availability: 24x7x365 with 99.9% uptime

2. Payment Service Providers (PSPs)

- Definition: RBI-authorized banks providing customer-facing UPI applications
- Regulatory Requirement: Must be regulated under Banking Regulation Act, 1949 with mobile banking authorization
- Mandatory Functions:

- Issue Virtual Payment Addresses (VPAs) to customers
- Provide PSP App with embedded NPCI libraries
- Support both Push (Pay) and Pull (Collect) transactions
- Implement device fingerprinting and authentication
- Support financial and non-financial transactions
- Provide dispute/complaint filing mechanism in-app

3. Issuer Banks

- Role: Maintain customer accounts, validate authentication (2nd factor), debit/credit accounts
- Functions: PIN/biometric validation, balance checks, fraud screening, settlement account maintenance

4. Technology Service Provider (TSP)

- Role: Outsourced technology infrastructure provider (permitted with conditions)
- Limitation: PSP functions cannot be outsourced; only technology platform may be outsourced

5. Remitter and Beneficiary

- Remitter: Customer initiating payment (payer)
- Beneficiary: Customer receiving payment (payee)

Address Types Supported:

Address Type	**Identifier**	**Resolution**	**Example**
Virtual Payment Address (VPA)	username@psp	PSP local mapper	john@paytm
Account Number + IFSC	A/C No + IFSC	NPCI central mapper	1234567890 + SBIN0001234
Aadhaar Number	12-digit Aadhaar	NPCI central mapper	1234 5678 9012

Mobile + MMID	Mobile No + MMID	NPCI central mapper	9876543210 + 1234567

PSP Handle Naming:

- Format: `username@psp`
- PSP handle allocated by NPCI (e.g., @paytm, @ybl, @axisbank)
- Maximum 3 handles per bank
- Must not resemble other PSP handles

Authentication Infrastructure:

NPCI Libraries:

- Embedded in PSP Apps (Android, iOS, Windows)
- Secure capture of credentials: OTP, PIN, biometrics
- PIN Encryption Flow:
    - PIN encrypted with NPCI Public Key (stored in library)
    - NPCI decrypts with NPCI Private Key
    - Re-encrypted with Issuer Bank's Public Key
    - Issuer Bank decrypts with Private Key using Hardware Security Module (HSM)

Biometric Authentication:

- Only UIDAI-supported biometrics allowed (IRIS, fingerprint)
- Validated by UIDAI (Trusted Third Party) on behalf of Issuer Bank
- Closed-loop biometric authentication not supported

Reference:

- UPI Procedural Guidelines, Version 1.5 (July 2016), Sections: Introduction, Membership Requirements, Payment Service Providers, Addresses Allowed, NPCI Libraries
- https://www.slbcmadhyapradesh.in/docs/UPI_Procedural_Guidelines24_12_2016.pdf

---

2.2 UPI Transaction Lifecycle (Step-by-step)

Transaction Types:

1. Pay Request (Push Transaction)

Customer pushes funds to beneficiary using VPA/Account/Aadhaar/Mobile+MMID

2. Collect Request (Pull Transaction)

Customer pulls funds from remitter using VPA only

- Expiry time: 30 minutes default (customer can set 1 minute to 45 days)

Step-by-Step Flow: Pay Request (Push)

Step 1: Transaction Initiation

- Remitter opens PSP App
- Enters beneficiary details (VPA/Account/Aadhaar)
- Enters amount and remarks
- Confirms transaction

Step 2: First Factor Authentication

- First Transaction: Mobile number validated by Issuer Bank
- Subsequent Transactions: Device fingerprint validated by PSP
- PSP verifies device binding and mobile number linkage

Step 3: Address Resolution

- If VPA: PSP resolves locally to account number + IFSC
- If Aadhaar: NPCI resolves to IIN (Issuer Identification Number), beneficiary bank resolves to account
- If Account + IFSC: Direct routing to beneficiary bank

Step 4: Second Factor Authentication

- Remitter enters UPI PIN or biometric on NPCI library interface
- PIN Flow:
    - Encrypted with NPCI Public Key
    - Sent to NPCI, decrypted with NPCI Private Key
    - Re-encrypted with Issuer Bank Public Key
    - Sent to Issuer Bank, decrypted with Private Key in HSM
    - Issuer Bank validates PIN

Step 5: Debit Authorization

- Issuer Bank performs:
    - PIN validation
    - Balance check

    - Limit check (per-transaction, daily limits)
    - Fraud scoring
    - Account status check
- Sends approval/decline response to NPCI

Step 6: Credit Processing

- If approved, NPCI sends credit request to beneficiary bank
- Beneficiary bank validates account details
- Credits beneficiary account

Step 7: Settlement

- Transaction settled via IMPS settlement mechanism
- Net positions calculated and settled through RTGS
- Settlement occurs in batches throughout the day

Step 8: Confirmation

- Both remitter and beneficiary receive transaction confirmation
- Optional: Credit Acknowledgement message sent from beneficiary bank to originating bank
- Originating bank may send SMS/email to remitter confirming credit to beneficiary

---

Step-by-Step Flow: Collect Request (Pull)

Step 1: Collect Request Initiation

- Beneficiary opens PSP App
- Creates collect request with remitter VPA, amount, expiry time
- Can be initiated from non-mobile channel (e.g., web), but authorization must occur on mobile

Step 2: Notification to Remitter

- NPCI routes collect request to remitter's PSP
- Remitter receives notification in PSP App
- Displays: requester VPA, amount, purpose, expiry time

Step 3: Remitter Authorization

- Remitter reviews collect request
- Accepts: Proceeds to authentication
- Rejects: Transaction cancelled
- Ignores: Expires after set time (default 30 minutes)

Step 4-8: Same as Pay Request Flow

- Once accepted, authentication and settlement follow same process as Pay Request

---

Pre-Approved Transactions:

When Payer PSP and Remitter Bank are same entity:

- PSP may send pre-approved transaction to NPCI (account already debited)
- NPCI processes only credit leg
- NPCI libraries optional in this case
- Enables ONUS (on-us) routing via internal bank processes

Transaction Limits:

- Default: ₹1 lakh per transaction (pegged to IMPS limit)
- Mandatory: Banks must set default limit to ₹1 lakh
- Cannot set different limits; approval required from IMPS/UPI Steering Committee for changes

Reference:

- UPI Procedural Guidelines, Version 1.5, Sections: Permitted Transaction Types, Authorization, UPI Transaction Flows, Annexure VI
- https://www.slbcmadhyapradesh.in/docs/UPI_Procedural_Guidelines24_12_2016.pdf

---

2.3 IMPS vs UPI Differences

Aspect	IMPS	UPI
Launch Year	2010	2016
Operator	NPCI	NPCI
Initiating Channel	Mobile banking, internet banking, SMS, ATM, bank branch	Mobile app (PSP App) primarily

Identifiers	Mobile + MMID, Account + IFSC	VPA, Account + IFSC, Aadhaar, Mobile + MMID
Push/Pull	Push only	Both Push (Pay) and Pull (Collect)
Authentication	MPIN, OTP	UPI PIN, Biometric (UIDAI), Device fingerprint
Per Transaction Limit	₹5 lakh	₹1 lakh
Settlement	Real-time via SGM	Real-time via IMPS settlement infrastructure
Address Resolution	NPCI central mapper (Mobile+MMID)	PSP local mapper (VPA) + NPCI central mapper (others)
Interface	Bank's mobile/internet banking app	Dedicated PSP App with NPCI libraries
Merchant Payments	Limited merchant payment support	Extensive merchant payment support (QR, Collect)
Availability	24x7x365	24x7x365

Settlement Guarantee	Yes (IMPS SGM)	Yes (via IMPS SGM framework)

Key Distinction:

- IMPS: Direct bank-to-bank transfer initiated via bank's own channels
- UPI: Interoperable payment interface allowing any PSP app to initiate transactions across any bank accounts, with simplified address resolution (VPA) and rich features (Collect, QR, etc.)

UPI Settlement via IMPS:

As per UPI Procedural Guidelines:

- UPI transactions where both debit and credit legs processed through UPI → settled via IMPS
- UPI debit + IMPS credit → settled via IMPS
- All UPI settlement files, NDC limits, and reports are part of IMPS settlement infrastructure

Reference:

- UPI Procedural Guidelines, Annexure I (Settlement & Reports)
- IMPS operational documentation (NPCI)

2.4 Settlement Cycles & Reconciliation

Settlement Infrastructure:

UPI Settlement via IMPS Mechanism:

Scenario 1: Sending Bank live in UPI + Recipient Bank live in IMPS only

- Debit: UPI
- Credit: IMPS
- Settlement: IMPS

Scenario 2: Both banks live in IMPS only (no UPI)

- Credit: IMPS
- Settlement: IMPS

Scenario 3: Both banks live in UPI

- Debit: UPI

- Credit: UPI
- Settlement: IMPS

NDC (Net Debit Cap) Allocation:

- Banks assigned specific percentage of existing IMPS NDC limit for UPI transactions
- NDC limit refreshed after each cutover/settlement cycle

Settlement Process:

1. Transaction Batching: NPCI consolidates UPI transactions at defined intervals
2. Net Position Calculation: For each bank, total credits minus total debits = net receivable/payable
3. Settlement File Generation: Daily Settlement Report (DSR), raw files, STL files created
4. RTGS Settlement: Net positions settled via RTGS (NPCI debits/credits bank settlement accounts at RBI)
5. File Distribution: Settlement files sent to banks via Secure File Transfer Protocol (SFTP) and made available on DMS/RGCS application
6. NDC Refresh: After settlement completion, NDC limits reset for next cycle

Settlement Charges:

- Net settlement amount includes:
    - Transaction fees
    - Interchange fees (between banks)
    - PSP fees
    - NPCI switching fees

NPCI Type-D RTGS Membership:

- NPCI holds Type-D RTGS membership with RBI
- Acts as settlement agency for interbank UPI transactions
- Authorized by RBI vide letter DAD/RTGS/626/24.02.001/2011-12 dated October 24, 2011

Reconciliation Requirements:

Daily Reconciliation Obligation:

- Banks must download settlement files daily
- Reconcile batch-wise outward and inward UPI transactions
- Match against settlement details and RBI account statements
- Investigate and follow-up on any mismatches with NPCI

Reporting:

- Members receiving "nil" transactions report if no activity in batch
- End-of-day summary report indicating all inward transactions

Operations Team Requirement:

- Banks must maintain separate operations and reconciliation team
- Handle day-to-day activities proactively and efficiently

Failure to Settle:

- Member failing to meet daily settlement obligation >2 times per month → debarred from membership
- Stringent action for insufficient balance in RTGS settlement account

Letter of Authority:

- Banks must issue letter of authority to RBI
- Authorizes RBI to debit/credit settlement account for UPI transactions
- Board-approved mandate required
- Existing IMPS mandate suffices for banks already live on IMPS

Reference:

- UPI Procedural Guidelines, Annexure I (Settlement & Reports)
- NEFT Procedural Guidelines, Section 7 (Inter-Bank Settlement)
- https://www.slbcmadhyapradesh.in/docs/UPI_Procedural_Guidelines24_12_2016.pdf

---

2.5 Dispute Management Flow

Customer Complaint Mechanism:

1. First Point of Contact

- For UPI transactions: Customer's PSP (Payment Service Provider)
- Alternative: Customer may approach remitter/beneficiary bank directly; banks must entertain all such requests

2. In-App Dispute Filing (Mandatory PSP Feature)

- PSP must provide option to raise dispute/complaint in PSP App
- Customer selects transaction from history OR enters transaction reference/ID
- Submits complaint with reason

3. PSP Due Diligence

- PSP reviews complaint details
- Verifies transaction status
- Investigates with remitter/beneficiary banks if needed

4. Registration in NPCI Back-Office

- After due diligence, PSP registers dispute in NPCI back-office system
- NPCI provides dispute tracking and resolution interface

5. Resolution TAT (Turnaround Time)

- PSPs must resolve complaints within TAT defined in UPI Operating and Settlement Guidelines
- TAT specific to complaint type (failed transaction, wrong credit, unauthorized transaction, etc.)

Dispute Categories:

1. Failed Transactions (Non-Refund)

- Scenario: Transaction debited but beneficiary not credited
- Resolution: PSP/bank investigates, coordinates with beneficiary bank
- Compensation: If delay due to bank negligence → Current RBI LAF Repo Rate + 2% for delay period

2. Successful Transaction but Non-Credit

- Scenario: Transaction marked successful but beneficiary claims non-receipt
- Resolution: Bilateral resolution between remitting and beneficiary banks
- Process: Beneficiary bank checks credit status, confirms to remitting bank

3. Unauthorized Transactions

- Scenario: Customer claims transaction not authorized
- Investigation: PSP and issuer bank verify device fingerprint, authentication logs
- Resolution: Reversal if proven unauthorized; customer liability if negligence established

4. Duplicate Debit

- Scenario: Amount debited multiple times for single transaction
- Resolution: PSP/bank identifies duplicate, processes refund

---

Transaction Status Check:

Mandatory PSP App Feature:

- Customer can check current status of any transaction
- Displays: Initiated, Pending, Success, Failed
- Shows failure reason if applicable

B+2 Return Discipline:

- Inward credit not returned within 2 hours of batch settlement = deemed completed/credited
- Critical: Beneficiary banks must return uneffected credits in immediate next batch
- If not returned within B+2 window, treated as successfully credited

---

Credit Acknowledgement (Optional):

- Remitter may provide mobile/email in transaction initiation
- Beneficiary bank sends Credit Acknowledgement to originating bank after crediting
- Originating bank sends SMS/email to remitter confirming credit to beneficiary

---

Escalation Mechanism:

Level 1: PSP/Bank Customer Care

Level 2: Nodal Officer at PSP/Bank

Level 3: Banking Ombudsman (if unresolved within 30 days)

Banking Ombudsman:

- RBI-operated grievance redressal mechanism
- Free of cost for customers
- Covers complaints not resolved satisfactorily by banks within 30 days

Reference:

- UPI Procedural Guidelines, Sections: Customer Complaints, Acknowledgement/Positive Confirmation, Return in Case of Non-Credit
- NEFT Procedural Guidelines, Section 8 (Rights and Obligations)
- https://www.slbcmadhyapradesh.in/docs/UPI_Procedural_Guidelines24_12_2016.pdf

---

2.6 Transaction Authentication Methods

Mandatory Two-Factor Authentication (2FA):

All UPI financial transactions require 2FA compliant with RBI guidelines.

Authentication Factors:

First Factor (Device/Knowledge):

Transaction Type	First Factor	Validated By
First Transaction	Mobile Number	Issuer Bank
Subsequent Transactions	Device Fingerprint	PSP

Device Fingerprinting Process:

- During customer registration, PSP sends automated encrypted SMS from customer's device
- SMS binds mobile number to device hardware fingerprint
- No customer intervention; fully automated
- Ensures transactions originate from hard-bound device

Second Factor (Possession/Biometric):

Option 1: UPI PIN

- 4-digit or 6-digit numeric PIN
- Entered via NPCI library (secure interface)
- Encrypted end-to-end using PKI

Option 2: Biometric Authentication

- Supported: IRIS scan, Fingerprint (via UIDAI)
- Validation: By UIDAI (Trusted Third Party) on behalf of Issuer Bank
- Not Supported: Locally stored biometrics (e.g., device fingerprint sensor without UIDAI validation)

PIN Handling Security (Critical):

Secure Capture via NPCI Libraries:

1. Customer enters PIN on NPCI library interface (embedded in PSP App during certification)
2. PIN encrypted with NPCI Public Key (stored in library)
3. Encrypted PIN traverses secure channel to NPCI

PKI Encryption Flow:

```text
Customer enters PIN
  ↓
NPCI Library encrypts with NPCI Public Key
  ↓
Encrypted PIN sent to NPCI
  ↓
NPCI decrypts with NPCI Private Key
  ↓
NPCI re-encrypts with Issuer Bank Public Key
  ↓
Encrypted PIN sent to Issuer Bank
  ↓
Issuer Bank decrypts with Issuer Private Key (using HSM only)
  ↓
Validation
```

Mandatory HSM Usage:

- Issuer Bank must decrypt PIN using Hardware Security Module (HSM) only
- No software-based PIN decryption permitted

Non-Financial Transaction Authentication:

Mobile Banking Registration:

- Requirements: Last 6 digits of debit card, expiry date, OTP
- Purpose: Elevates SMS-alert-registered mobile number to mobile banking
- Channel: PSP App only

- Validation: By Issuer Bank

Set/Change PIN:

- Requirements: OTP sent to registered mobile
- Channel: PSP App only
- Binding: PIN linked to account and device

Generate OTP:

- Purpose: Request OTP for various services
- Delivery: SMS to registered mobile
- Validity: Typically 10 minutes

Pre-Approved Transaction Authentication:

When Payer PSP = Remitter Bank:

- PSP may use alternate authentication (not NPCI libraries)
- Account already debited before sending to NPCI
- Only credit leg processed by NPCI
- Useful for ONUS transactions (within same bank)

Mandatory NPCI Library Usage:

When Payer PSP ≠ Remitter Bank:

- PSP must use NPCI libraries for PIN capture
- Both debit and credit legs processed by NPCI

Security Considerations:

App Security:

- PSP App certified by NPCI before go-live
- NPCI libraries embedded during certification process
- Cannot be modified post-certification

Device Security:

- Device fingerprinting prevents SIM swap fraud
- Hard binding between mobile number and device hardware

Network Security:

- All communication via SFMS (Structured Financial Messaging Solution)
- Encrypted channels between PSP, NPCI, Issuer Bank

Unsolicited Pull Request Protection:

- Customer in complete control; must enter authentication to approve
- Collect requests expire if not acted upon
- No auto-debit without explicit customer authorization

Reference:

- UPI Procedural Guidelines, Sections: Authorization, Transacting Parties, NPCI Libraries, Security Procedure, Annexure XIII (Broad Security Considerations)
- RBI Guidelines on Two-Factor Authentication (2025 update effective April 1, 2026)
- https://www.slbcmadhyapradesh.in/docs/UPI_Procedural_Guidelines24_12_2016.pdf
- https://www.newsonair.gov.in/reserve-bank-of-india-enhances-digital-payment-security-with-new-guidelines/

SECTION 3: KYC & AML COMPLIANCE DOCUMENTATION

3.1 KYC Master Direction (RBI)

Legal Framework:

Primary Regulation:

Master Direction – Know Your Customer (KYC) Direction, 2016

Issued by Reserve Bank of India under Section 35A of Banking Regulation Act, 1949 and Section 45JA of RBI Act, 1934.

Supporting Legislation:

- Prevention of Money-Laundering Act (PMLA), 2002
- Prevention of Money-Laundering (Maintenance of Records) Rules, 2005
- Payment and Settlement Systems Act, 2007 (for payment system entities)

Applicability:

The KYC Master Direction applies to the following Regulated Entities (REs):

1. Banks:

    - All Scheduled Commercial Banks (SCBs)
    - Regional Rural Banks (RRBs)
    - Local Area Banks (LABs)
    - Primary (Urban) Co-operative Banks (UCBs)
    - State and Central Co-operative Banks (StCBs / CCBs)
    - Any entity licensed under Section 22 of Banking Regulation Act, 1949
2. All India Financial Institutions (AIFIs)
3. Non-Banking Financial Companies (NBFCs):
    - NBFCs, Miscellaneous Non-Banking Companies (MNBCs)
    - Residuary Non-Banking Companies (RNBCs)
4. Asset Reconstruction Companies (ARCs)
5. Payment System Entities:
    - Payment System Providers (PSPs)
    - System Participants (SPs)
    - Prepaid Payment Instrument Issuers (PPI Issuers)
6. Authorised Persons (APs):
    - Including agents of Money Transfer Service Scheme (MTSS)

Key Objectives:

1. Prevent Money Laundering: Detect and deter use of financial system for money laundering
2. Counter Terrorist Financing: Identify and block funding to terrorist activities
3. Customer Identification: Establish true identity of customers
4. Risk Assessment: Categorize customers based on risk profile
5. Transaction Monitoring: Identify unusual or suspicious transaction patterns
6. Compliance with FATF: Adhere to Financial Action Task Force (FATF) international standards

Reference:

- Master Direction – Know Your Customer (KYC) Direction, 2016 (RBI)
- Prevention of Money-Laundering Act (PMLA), 2002
- Prevention of Money-Laundering (Maintenance of Records) Rules, 2005
- https://www.lawrbit.com/article/master-direction-kyc-ensuring-financial-integrity-and-security/

3.2 Customer Due Diligence (CDD)

Definition:

Customer Due Diligence (CDD) is the process of identifying and verifying the identity

of customers, understanding the nature of their business/transactions, and assessing the risk they pose to the financial institution.

CDD Components:

1. Customer Acceptance Policy (CAP)

Mandatory Elements:

- Criteria for accepting customers (risk-based)
- Guidelines for high-risk customers
- Circumstances under which account opening will be refused
- Documentary requirements for different customer categories
- Prohibition: No account opened in fictitious or anonymous name

Risk Categories:

- Low Risk: Government employees, public sector employees, regulated entities
- Medium Risk: General customers, small businesses
- High Risk: Politically Exposed Persons (PEPs), Non-Resident Indians (NRIs), high-value cash transactions, cross-border remitters

---

2. Customer Identification Procedures (CIP)

Objective: Verify customer identity using reliable, independent documents before establishing relationship

Acceptable Identity Documents:

For Individuals:

- Primary: Aadhaar Card, PAN Card, Passport, Voter ID, Driving License
- Address Proof: Utility bills (electricity/water/gas), bank statement, rent agreement, Aadhaar (for address)
- Photograph: Recent passport-size photo

For Business Entities:

Entity Type	Required Documents

Sole Proprietorship	Proprietor's PAN, Aadhaar/Voter ID, Business registration (GST/MSME/Udyam), Shop & Establishment certificate
Partnership Firm	Partnership Deed, PAN of firm, PAN & identity proof of partners, Board Resolution
Private/Public Limited Company	Certificate of Incorporation, PAN of company, MOA/AOA, Board Resolution, Director KYC (DIN, PAN, Aadhaar)
Trust/NGO	Trust Deed, Registration Certificate, PAN of trust, Resolution letter for signatory authorization, Trustee KYC
LLP	LLP Agreement, Certificate of Incorporation, PAN of LLP, Partner KYC

For Payment Gateway/Aggregator Merchants:

- PAN Card (mandatory for all)
- GST Registration Certificate (if turnover exceeds threshold)
- Cancelled cheque or bank statement
- Business proof (website, app link, business registration)
- PMLA compliance: Merchant KYC mandatory for all RBI-regulated payment gateways

---

3. Verification Process

In-Person Verification (IPV):

- For high-risk customers or specific circumstances
- Physical presence of customer required
- Document originals verified

Electronic Verification:

- Aadhaar-based e-KYC (UIDAI authentication)
- DigiLocker for document verification

- Central KYC Records Registry (CKYCR) data fetch
- Video KYC (V-CKY) as per RBI guidelines

Timing: Verification must be completed before establishing account relationship or conducting transaction

---

4. Beneficial Ownership Identification

Requirement: Identify ultimate beneficial owner (natural person) for legal entities

Threshold: Individual holding >25% equity or control

Documentation: Declaration from customer identifying beneficial owners with supporting documents

---

5. Ongoing Due Diligence

Periodic KYC Updates:

Risk Category	Update Frequency
Low Risk	Every 10 years
Medium Risk	Every 8 years
High Risk	Every 2 years

Additional Requirements:

- Update customer profile when material changes occur
- Re-verify identity documents on expiry
- Monitor transaction patterns against customer profile

---

6. Simplified Due Diligence (SDD)

Applicability: For low-risk customers

Examples:

- Government departments
- Public Sector Undertakings
- Basic Savings Bank Deposit (BSBD) accounts with limits

Simplified Measures:

- Reduced documentation
- Lower verification requirements
- Simplified ongoing monitoring

---

7. Record Maintenance

Mandatory Records:

- All identity documents and verification records
- Account opening forms
- Transaction records
- Customer communication records

Retention Period: Minimum 5 years after closure of account or business relationship

Accessibility: Records must be easily retrievable for audits, investigations, and regulatory inspections

Reference:

- Master Direction – Know Your Customer (KYC) Direction, 2016, Section on Customer Due Diligence
- PMLA Rules, 2005, Rule 9 (maintenance of records)
- https://www.lawrbit.com/article/master-direction-kyc-ensuring-financial-integrity-and-security/
- https://razorpay.com/blog/documents-required-for-payment-gateway

---

3.3 Enhanced Due Diligence (EDD)

Definition:

Enhanced Due Diligence (EDD) is a heightened level of scrutiny applied to high-risk

customers or transactions to mitigate increased money laundering and terrorist financing risks.

When EDD is Required:

1. High-Risk Customer Categories:
    - Politically Exposed Persons (PEPs): Individuals holding prominent public functions (current or former), their family members and close associates
    - Non-Resident Indians (NRIs) and Foreign Nationals
    - High Net-Worth Individuals (HNWIs) with complex ownership structures
    - Trusts, NGOs, Charities receiving donations
    - Companies with nominee shareholders or bearer share structure
    - Customers from high-risk jurisdictions (as per FATF list)
2. High-Risk Transactions:
    - Large cash transactions (above specified thresholds)
    - Complex or unusually large transactions inconsistent with customer profile
    - Cross-border wire transfers from/to high-risk countries
    - Transactions with no apparent economic purpose
3. Suspicious Activity:
    - Transaction patterns not consistent with customer's stated business/profile
    - Attempts to avoid reporting thresholds (structuring)
    - Customer reluctance to provide information or documents

---

EDD Measures:

1. Additional Information Gathering

- Source of wealth and source of funds
- Purpose of account/relationship
- Nature and location of business activities
- Expected volume and nature of transactions
- Beneficial ownership details (beyond standard CDD)

2. Enhanced Verification

- Independent verification of information provided
- Obtain information from multiple sources

- Third-party references and background checks
- Verification of business premises

3. Senior Management Approval

- Approval from senior management or designated authority to establish/continue relationship
- Documented rationale for acceptance

4. Intensified Monitoring

- More frequent transaction monitoring
- Lower thresholds for triggering alerts
- Periodic review of relationship (at least annually for high-risk)
- Real-time monitoring for very high-risk customers

5. Additional Documentation

- Explanation for unusual transactions
- Supporting documents for large transactions (invoices, contracts, proof of business activity)
- Updated information at shorter intervals

Politically Exposed Persons (PEPs) - Specific Requirements:

Identification:

- Senior government officials, political party leaders, senior military officers
- Executives of state-owned enterprises
- Judicial and legislative officials
- Family Members: Spouse, parents, siblings, children
- Close Associates: Business partners, co-beneficiaries of legal entities

EDD for PEPs:

- Senior management approval mandatory
- Determine source of wealth and funds
- Continuous monitoring of relationship
- Immediate reporting of suspicious transactions
- Periodic reviews (at least annually)

Non-Resident Indians (NRIs) - Specific Considerations:

Additional Verification:

- Proof of overseas residence (visa, employment, residence permit)
- Source of funds for remittances to India
- Purpose of NRE/NRO account opening

FEMA Compliance:

- Ensure credits to NRE accounts comply with Foreign Exchange Management Act (FEMA) regulations
- Verify eligibility for repatriation

NGOs and Trusts - Enhanced Scrutiny:

Due to High Vulnerability:

- Source of donations (domestic/international)
- Utilization of funds (alignment with stated objectives)
- Key functionaries and beneficiaries
- Registration status and compliance with FCRA (Foreign Contribution Regulation Act)

Rejection/Exit of Relationship:

If EDD cannot be completed satisfactorily:

- Option 1: Reject account opening
- Option 2: Terminate existing relationship
- Mandatory: File Suspicious Transaction Report (STR) if warranted

Reference:

- Master Direction – Know Your Customer (KYC) Direction, 2016, Section on Enhanced Due Diligence
- FATF Guidance on PEPs
- https://www.lawrbit.com/article/master-direction-kyc-ensuring-financial-integrity-and-security/

3.4 AML Monitoring Process

Definition:

Anti-Money Laundering (AML) monitoring is the systematic process of tracking and analyzing customer transactions to detect patterns indicative of money laundering, terrorist financing, or other financial crimes.

AML Framework Components:

1. Risk-Based Approach

Customer Risk Assessment:

- Categorize each customer into risk buckets: Low, Medium, High
- Factors considered:
    - Customer profile (occupation, income, business nature)
    - Geographic location
    - Transaction patterns
    - Product/service usage
    - Delivery channels

Transaction Risk Assessment:

- Cash-intensive transactions
- High-value transactions
- Cross-border transactions
- Transactions with high-risk jurisdictions
- Use of multiple accounts/instruments

---

2. Transaction Monitoring Systems

Automated Monitoring:

- Software/Algorithms: Real-time and batch processing systems analyze transaction data
- Rule-Based Systems: Predefined rules trigger alerts (e.g., cash deposit >₹10 lakh, multiple transactions just below threshold)
- Behavior Analytics: Machine learning models detect deviations from normal patterns
- Velocity Checks: Monitor frequency and volume of transactions over time

Monitoring Parameters:

- Transaction amount thresholds
- Transaction frequency
- Geographic patterns (sender/receiver locations)
- Time-of-day patterns
- Inconsistency with customer profile
- Structuring (breaking large transactions into smaller amounts)

- Round-tripping (funds moving in circular pattern)

---

3. Alert Generation & Investigation

Alert Triggers:

- Threshold breaches (e.g., cash >₹10 lakh)
- Pattern anomalies (sudden spike in activity)
- Unusual beneficiaries (high-risk jurisdictions)
- Watch-list matches (PEP, sanctions lists)

Investigation Process:

1. Alert Review: AML compliance officer reviews alert
2. Data Gathering: Collect customer profile, transaction history, supporting documents
3. Risk Assessment: Determine if activity is consistent with customer's legitimate business
4. Escalation: If suspicious, escalate for STR filing; if legitimate, close alert with documentation

---

4. Cash Transaction Reporting (CTR)

Mandatory Reporting:

- All cash transactions (deposits + withdrawals) aggregating ≥₹10 lakh in a day
- Reported to Financial Intelligence Unit-India (FIU-IND)
- Format: Cash Transaction Report (CTR)
- Timeline: Monthly submission by 15th of following month

---

5. Suspicious Transaction Reporting (STR)

Covered in Section 3.6 below

---

6. Watch-List Screening

Lists Screened:

- UNSC 1267 Sanctions List: UN designated terrorists/entities
- OFAC SDN List: US Office of Foreign Assets Control specially designated nationals

- EU Sanctions Lists
- RBI/Government of India Prohibited Lists
- PEP Databases

Screening Frequency:

- At onboarding (KYC)
- Ongoing monitoring (daily/real-time for transactions)
- Upon list updates

Action on Match:

- Freeze transaction/account
- Report to FIU-IND immediately
- Await instructions from authorities

---

7. Employee Training

Mandatory Requirements:

- Annual AML/KYC training for all employees
- Specialized training for front-line staff (account opening, transaction processing)
- Focus areas:
    - Identification of suspicious transactions
    - Red flag indicators
    - Reporting procedures
    - Regulatory updates

---

8. Independent Audit

Annual AML Audit:

- Conducted by internal audit or external CISA/CA
- Assess adequacy of AML/KYC framework
- Test effectiveness of controls
- Report submitted to Board and RBI

Red Flag Indicators for Money Laundering:

- Large cash deposits inconsistent with customer profile
- Frequent deposits just below reporting threshold (structuring)
- Deposits followed by immediate wire transfers, especially overseas

- Use of multiple accounts/branches for same customer
- Transactions with no apparent business purpose
- Customer reluctance to provide information or documents
- Use of third-party checks without reasonable explanation
- Dormant account suddenly becoming active with large transactions
- Complex ownership structures with no clear economic rationale

Reference:

- Master Direction – Know Your Customer (KYC) Direction, 2016, Sections on Risk Management and Monitoring
- PMLA, 2002 and Rules, 2005
- FIU-IND Guidelines
- https://www.lawrbit.com/article/master-direction-kyc-ensuring-financial-integrity-and-security/

3.5 Transaction Monitoring Mechanisms

Transaction Monitoring Framework:

1. Real-Time Monitoring

Immediate Screening:

- Every transaction screened against predefined rules at point of initiation
- Checks performed:
    - Transaction amount vs. customer limits
    - Watch-list matching (sender/receiver)
    - Sanctions screening
    - Fraud scoring

Decisioning:

- Pass: Transaction proceeds
- Alert: Transaction held for review (may proceed after manual approval)
- Block: Transaction rejected

---

2. Batch Monitoring

End-of-Day Analysis:

- Aggregate all day's transactions per customer
- Apply daily/monthly thresholds

- Pattern analysis across time periods

Periodic Reviews:

- Weekly/monthly transaction pattern analysis
- Trend identification
- Comparison against peer groups

---

3. Scenario-Based Monitoring

Common AML Scenarios:

Scenario 1: Structuring/Smurfing

- Pattern: Multiple deposits just below ₹10 lakh threshold in short period
- Detection: Aggregate cash deposits over rolling 7-day/30-day window

Scenario 2: Rapid Movement

- Pattern: Funds deposited and immediately withdrawn/transferred
- Detection: Time between credit and debit <24/48 hours

Scenario 3: Dormancy Followed by Activity

- Pattern: Long-dormant account suddenly active with large transactions
- Detection: Compare current activity vs. 6-month/12-month history

Scenario 4: Layering

- Pattern: Funds transferred through multiple accounts in quick succession
- Detection: Track fund flow across linked accounts

Scenario 5: Round-Tripping

- Pattern: Funds transferred out and back to originating account through intermediaries
- Detection: Beneficiary analysis and circular flow identification

Scenario 6: Transactions with High-Risk Jurisdictions

- Pattern: Cross-border transfers to/from FATF-identified high-risk countries
- Detection: Geographic risk scoring

---

4. Threshold-Based Monitoring

Regulatory Thresholds:

Transaction Type	Threshold	Reporting
Cash deposit/withdrawal	₹10 lakh per day	CTR to FIU-IND
Suspicious transaction	Any amount	STR to FIU-IND
Cash transactions by non-account holders	₹50,000 (NEFT)	Enhanced KYC
Wire transfers	Full details mandatory	Wire Transfer Guidelines

Internal Thresholds:

- Banks may set lower thresholds for specific customer categories
- High-risk customers may have real-time monitoring for all transactions

---

5. Peer Group Analysis

Methodology:

- Group customers with similar profiles (industry, geography, size)
- Compare individual customer's activity against peer average
- Flag outliers for investigation

Use Case:

- Retailer depositing 5x peer average cash → potential tax evasion or unaccounted income

---

6. Link Analysis

Network Detection:

- Identify relationships between customers (same address, phone, IP, beneficiaries)

- Detect coordinated activity across linked accounts
- Identify layering through related entities

Graph Analytics:

- Visualize fund flows
- Detect circular transactions
- Identify central nodes in suspicious networks

---

7. Machine Learning Models

Advanced Analytics:

- Anomaly Detection: Unsupervised learning to identify unusual patterns not captured by rules
- Predictive Models: Supervised learning to predict likelihood of money laundering based on historical STRs
- Behavioral Profiling: Establish normal behavior baseline, flag deviations

Benefits:

- Reduce false positives
- Detect sophisticated laundering techniques
- Adapt to evolving patterns

---

8. False Positive Management

Challenge: High volume of alerts, many false positives

Strategies:

- Tuning: Refine rules based on historical false positive analysis
- Risk Scoring: Prioritize alerts based on risk scores
- Whitelisting: Suppress known-good patterns (e.g., salary credits)
- Machine Learning: Use ML to reduce noise

---

9. Reporting & Escalation

Internal Reporting:

- Daily alert summaries to AML compliance officer
- Monthly AML metrics to senior management/Board
- Metrics: Alerts generated, STRs filed, accounts closed, training completion

Regulatory Reporting:

- Cash Transaction Reports (CTR) - Monthly
- Suspicious Transaction Reports (STR) - Within 7 days of suspicion
- Watch-list match reports - Immediate

Reference:

- Master Direction – Know Your Customer (KYC) Direction, 2016
- PMLA Rules, 2005
- FIU-IND formats and guidelines
- https://www.lawrbit.com/article/master-direction-kyc-ensuring-financial-integrity-and-security/

3.6 Suspicious Transaction Reporting (STR)

Legal Obligation:

Prevention of Money Laundering Act (PMLA), 2002 and PMLA Rules, 2005 mandate all banking companies, financial institutions, and intermediaries to furnish details of suspicious transactions to Financial Intelligence Unit-India (FIU-IND).

Definition of Suspicious Transaction:

A transaction (including attempted transaction) that:

- Gives rise to reasonable grounds to believe it may involve proceeds of crime
- Appears inconsistent with customer's known legitimate business/sources of income
- Has no apparent economic rationale or bona fide purpose
- Involves funds suspected to be linked to money laundering or terrorist financing

---

STR Filing Obligation:

Who Must File:

- Banks (all categories)
- NBFCs
- Payment system operators and participants
- PPI issuers

- Payment aggregators
- Money transfer service providers
- All entities covered under PMLA, 2002

When to File:

- Timeline: Within 7 working days of transaction being identified as suspicious
- Threshold: No minimum threshold - any amount if suspicious
- Attempt: Even attempted transactions must be reported

Confidentiality:

- Tipping Off Prohibition: Regulated entity must NOT inform customer that STR has been filed
- Internal Confidentiality: STR filing known only to compliance officer and authorized personnel
- Penalty for Tipping Off: Criminal prosecution under PMLA

STR Indicators (Red Flags):

Customer Behavior:

- Customer reluctant to provide information or provides suspicious/false information
- Customer requests transactions designed to avoid reporting requirements
- Customer makes frequent deposits below reporting threshold (structuring)
- Customer has multiple accounts with no apparent purpose
- Customer avoids personal contact with institution

Transaction Patterns:

- Large cash transactions inconsistent with customer profile
- Deposits followed immediately by wire transfers, especially overseas
- Frequent exchange of small bills for large bills or vice versa
- Use of multiple branches/accounts for same transaction
- Transactions involving high-risk jurisdictions (as per FATF)
- Complex transactions with no economic purpose

Account Activity:

- Dormant account suddenly active with large transactions
- Pass-through activity (in and out rapidly)
- Round-tripping of funds
- Deposits of third-party checks without reasonable explanation
- Large deposits of traveler's checks or money orders

Business/Trade Transactions:

- Trade transactions with overvalued/undervalued goods (trade-based money laundering)
- Import/export transactions inconsistent with customer's business
- Advance remittance for goods without documentation
- Circular trading patterns

Third-Party Involvement:

- Frequent use of third-party checks with no apparent connection to customer
- Multiple individuals depositing to same account
- Customer allows others to use account (layering)

STR Filing Process:

Step 1: Detection

- Transaction monitoring system generates alert OR
- Employee identifies suspicious activity manually

Step 2: Investigation

- Assigned investigator reviews transaction, customer profile, history
- Gathers supporting information
- Assesses whether activity warrants STR

Step 3: Decision

- Principal Officer (designated AML compliance officer) reviews
- Determines if transaction meets STR criteria
- Approves STR filing

Step 4: Filing with FIU-IND

- STR filed electronically via FIU-IND portal (FINnet)
- Format: Prescribed STR format (varies by entity type)
- Information Included:
    - Customer details (name, address, ID documents)
    - Transaction details (date, amount, type, parties involved)
    - Nature of suspicion with detailed narrative
    - Supporting documents (if available)

Step 5: Follow-Up

- Maintain copy of STR and supporting documents (5 years minimum)
- Monitor account for further suspicious activity
- Respond to FIU-IND queries if any

Distinction: STR vs CTR

Aspect	STR	CTR
Basis	Suspicion of money laundering	Regulatory threshold breach
Threshold	No minimum (any amount)	₹10 lakh or more cash per day
Timeline	Within 7 days of suspicion	Monthly by 15th of next month
Subjectiv e	Requires judgment call	Objective (automatic if threshold met)
Action	May trigger investigation	Statistical/database purpose

---

Principal Officer Responsibility:

Designation:

- Every regulated entity must appoint a Principal Officer
- Designated as central point for AML compliance
- Reports directly to senior management/Board

Duties:

- Receive internal STR/CTR reports
- Review and approve STR filings
- Liaise with FIU-IND and law enforcement
- Maintain STR/CTR records
- Conduct AML training
- Ensure compliance with PMLA

Consequences of Non-Compliance:

For Institutions:

- Monetary penalties up to ₹1 lakh per violation (Section 13 of PMLA)
- RBI enforcement actions (suspension of business, license cancellation)
- Reputational damage

For Individuals (Principal Officer/Employees):

- Imprisonment up to 3-7 years for tipping off
- Criminal prosecution for willful non-compliance

Case Example: Manappuram Finance Limited

Violation: Non-compliance with KYC norms and PPI regulations

Penalty: ₹17 lakh imposed by RBI (April 18, 2022)

Legal Basis: Section 30 of Payment and Settlement Systems Act, 2007

Takeaway: RBI actively monitors and penalizes non-compliance

Reference:

- Prevention of Money-Laundering Act (PMLA), 2002
- Prevention of Money-Laundering (Maintenance of Records) Rules, 2005
- FIU-IND STR formats and guidelines
- Master Direction – Know Your Customer (KYC) Direction, 2016
- https://www.dor.gov.in/str-suspicious-transaction-reports
- https://www.lawrbit.com/article/master-direction-kyc-ensuring-financial-integrity-and-security/

SECTION 4: PAYMENT GATEWAY PROCESS DOCUMENTATION

4.1 Payment Initiation Flow

Payment Gateway Architecture:

System Actors:

1. Customer (Payer): Initiates payment on merchant website/app
2. Merchant: Business accepting payments (e-commerce, service provider)
3. Payment Gateway: Technology platform aggregating payments (e.g., Razorpay, Paytm, CCAvenue)

4. Payment Aggregator (PA): Entity facilitating aggregation of payments (may be same as gateway or separate)
5. Acquirer Bank: Merchant's bank (receives funds on behalf of merchant)
6. Card Network: Visa, Mastercard, RuPay (for card transactions)
7. Issuer Bank: Customer's bank (debits customer account)

Step-by-Step Payment Initiation:

Step 1: Customer Action

- Customer selects product/service on merchant website/app
- Proceeds to checkout
- Clicks "Pay Now" or equivalent

Step 2: Merchant System

- Merchant system creates order with:
    - Order ID (unique identifier)
    - Amount
    - Customer details (name, email, phone)
    - Product/service description
- Redirects customer to payment gateway checkout page

Step 3: Payment Gateway Interface

- Customer lands on payment gateway's secure checkout interface
- Gateway displays:
    - Merchant name and logo
    - Transaction amount
    - Payment method options (credit card, debit card, UPI, net banking, wallets)

Step 4: Payment Method Selection

- Customer selects preferred payment method
- For cards: Enters card number, expiry, CVV, cardholder name
- For UPI: Enters VPA or scans QR code
- For net banking: Selects bank
- For wallet: Logs into wallet account

Step 5: Data Capture & Encryption

- Payment gateway captures payment credentials
- Card details encrypted using SSL/TLS
- PCI-DSS compliant tokenization (card number replaced with token)
- Data sent securely to payment processor

Step 6: Fraud Screening

- Payment Service Provider (PSP) performs checks:
    - BIN Check: Card Bank Identification Number validation
    - Fraud Scoring: Risk assessment using ML models (device fingerprinting, IP geolocation, transaction patterns)
    - 3D Secure: Determines if additional authentication needed (OTP via ACS)
    - CVV Check: Validates Card Verification Value

Step 7: Routing Decision

- Gateway determines routing path:
    - Card Network: Visa/Mastercard/RuPay for card transactions
    - UPI Switch: NPCI for UPI transactions
    - Bank PG: Direct to issuer bank for net banking
- Converts transaction to appropriate message format (ISO 8583 for cards, ISO 20022)

Reference:

- Razorpay Payment Gateway documentation
- https://www.linkedin.com/posts/marcelvanoost_acquirer-issuer-the-different-authorization-activity-7258450778309152768-N_dl
- https://payu.in/blog/merchant-payment-gateway-types-and-benefits/

4.2 Authorization & Authentication

Authorization Process:

Step 1: Acquirer Processing

- Payment gateway/acquirer receives encrypted payment credentials
- Performs:
    - Transaction validation (amount, merchant ID, card expiry)
    - Additional fraud checks
    - Compliance checks (sanctions screening)

Step 2: Card Network Routing

- Acquirer sends authorization request to card network (Visa/Mastercard/RuPay)
- Card network:
    - Detokenizes payment transaction (if tokenized)
    - Validates transaction format

    - Performs network-level fraud checks
    - Routes to issuer bank based on BIN

Step 3: Issuer Bank Validation

- Issuer bank receives authorization request
- Runs comprehensive validations:
    - PIN Check: For debit card with PIN
    - Address Verification (AVS): Matches billing address
    - Chip Verification: For EMV chip cards (card-present)
    - CVV/CVV2 Check: Validates security code
    - Limit Check: Per-transaction and daily limits
    - Balance Check: Sufficient funds/credit available
    - Account Status Check: Not blocked/frozen
    - Fraud Rules: Bank's proprietary fraud detection

Step 4: Authorization Decision

- Issuer bank makes decision:
    - Approved: Sufficient funds, all checks passed → Authorization code generated
    - Declined: Insufficient funds, limits exceeded, fraud suspicion, card blocked
    - Refer to Issuer: Additional verification needed (customer should contact bank)

Step 5: Response Routing

- Authorization response sent back through chain:
    - Issuer Bank → Card Network → Acquirer Bank → Payment Gateway → Merchant
- Response Codes: Standard codes (e.g., "00" = Approved, "05" = Do not honor, "51" = Insufficient funds)

Step 6: Authorization Hold (for Credit Cards)

- If approved, issuer places authorization hold on customer's account
- Amount blocked but not yet debited
- Hold typically valid for 3-7 days (varies by card network)

Authentication Methods:

1. Card Not Present (CNP) - Online Transactions

3D Secure Authentication:

- Visa: Verified by Visa (VbV)
- Mastercard: Mastercard SecureCode
- RuPay: RuPay Secure

Process:

- Customer redirected to Access Control Server (ACS) hosted by issuer bank
- Enters OTP sent to registered mobile/email OR uses biometric via bank app
- Bank validates OTP/biometric
- Returns authentication result to card network → gateway → merchant

RBI Mandate (effective April 1, 2026):

- All digital payments must use at least one changing proof (OTP, PIN, biometric)
- Two-factor authentication mandatory (excluding card-present transactions)

2. Card Present - Physical Transactions

- EMV Chip + PIN: Standard for debit cards
- Contactless (NFC): Tap-to-pay for small amounts (typically <₹5,000, no PIN required)
- Magnetic Stripe: Legacy, being phased out

3. UPI Authentication

- Covered in Section 2.6 (UPI transaction authentication)

4. Net Banking

- Customer logs into bank's internet banking portal
- Authenticates using username/password + OTP/security questions
- Approves payment on bank's interface

5. Wallet

- Customer logs into wallet app/web
- Authenticates using wallet PIN/biometric/OTP
- Approves payment

Authentication Result Codes:

3D Secure Status:

- Y (Success): Authentication successful, transaction fully authenticated
- A (Attempted): Authentication attempted but not completed (technical issue)
- N (Failed): Authentication failed, transaction should be declined
- U (Unavailable): Authentication not available for this card

Liability Shift:

- With 3D Secure: Liability shifts to issuer bank (protected from chargebacks)
- Without 3D Secure: Merchant bears fraud liability

Reference:

- RBI Guidelines on Two-Factor Authentication (2025)
- Payment Card Industry Data Security Standard (PCI-DSS)
- https://www.newsonair.gov.in/reserve-bank-of-india-enhances-digital-payment-security-with-new-guidelines/
- https://juspay.io/en-in/blog/payment-authorization
- https://payu.in/blog/merchant-payment-gateway-types-and-benefits/

4.3 Payment Gateway Role

Core Functions:

1. Aggregation

- Consolidates payments from multiple customers on behalf of merchant
- Single settlement to merchant for all transactions
- Eliminates need for merchant to have individual relationships with multiple banks/card networks

2. Multi-Channel Support

- Accepts payments via:
    - Website (API integration, hosted checkout)
    - Mobile app (SDK integration)
    - Payment links (no website/app needed)
    - QR codes
    - Point-of-Sale (POS) terminals (for physical payments)

3. Multiple Payment Methods

- 100+ payment modes supported (example: Razorpay)
    - Credit cards (Visa, Mastercard, RuPay, Amex, Diners)
    - Debit cards (all major banks, card networks)
    - UPI (all PSP apps)
    - Net banking (50+ banks)
    - Wallets (Paytm, PhonePe, Amazon Pay, Mobikwik, etc.)
    - BNPL (Buy Now Pay Later) - emerging
    - EMI options
    - International cards (for cross-border)

4. Secure Data Handling

- PCI-DSS Level 1 Certification: Highest security standard for payment data
- Tokenization: Replace card numbers with tokens (non-reversible without key)
- Encryption: End-to-end encryption for data in transit
- Secure Storage: Encrypted vault for recurring payment credentials

5. Fraud Prevention

- Real-time fraud scoring using machine learning
- Device fingerprinting (tracks device, browser, IP)
- Behavioral analytics (pattern detection)
- Sanctions screening (OFAC, UNSC lists)
- Velocity checks (transaction frequency limits)
- Rule engine (custom rules by merchant)

6. Transaction Routing & Optimization

- Smart Routing: Route to acquirer/bank with highest success rate
- Retry Logic: Auto-retry failed transactions with alternate routes
- Load Balancing: Distribute transactions across multiple acquirers
- Currency Conversion: For international transactions (DCC - Dynamic Currency Conversion)

7. Settlement & Reconciliation

- Consolidate successful transactions
- Deduct gateway fees and charges
- Transfer net amount to merchant's bank account
- Provide detailed settlement reports (daily, weekly, monthly)
- Automated reconciliation with merchant's order system

8. Reporting & Analytics

- Real-time transaction dashboard
- Success/failure rate analysis
- Payment method performance
- Customer payment behavior insights
- Refund and chargeback tracking
- GST and TDS reports

9. Dispute Management

- Handle customer disputes and chargeback inquiries
- Collect evidence from merchant
- Represent to acquirer/card network
- Track dispute lifecycle

10. Compliance

- RBI Compliance: Adhere to PA-O/PA-P/PA-CB regulations (as applicable)
- KYC/AML: Conduct merchant KYC per PMLA requirements
- Data Localization: Store payment data in India (per RBI mandate)
- Reporting: Submit reports to RBI, FIU-IND as required
- Audits: Annual security audits, VAPT (bi-annual)

Integration Models:

1. Hosted Checkout Page

- Merchant redirects customer to gateway's checkout page
- Gateway handles all payment UI and processing
- Customer returns to merchant site after payment
- Ease: Easiest integration (no PCI-DSS burden on merchant)

2. API Integration (Server-to-Server)

- Merchant collects payment details on own page
- Sends to gateway via secure API
- Control: Full UI control but merchant must be PCI-DSS compliant

3. SDK Integration (Mobile Apps)

- Payment gateway SDK embedded in merchant's mobile app
- Native payment experience
- Popular: For iOS and Android apps

4. Payment Links

- Gateway generates unique payment link
- Merchant shares via WhatsApp, SMS, email
- Use Case: No website/app needed (instant setup)

5. Payment Buttons

- Simple HTML button embedded on website
- Copy-paste integration (no coding)
- Use Case: Small merchants, quick setup

Fee Structure:

Typical Charges:

- Transaction Fee: 1.5% - 2.5% per transaction (varies by payment method)
- Setup Fee: ₹0 to ₹5,000 (often waived)

- Annual Maintenance: ₹0 to ₹10,000
- Chargeback Fee: ₹500 to ₹1,000 per chargeback
- Refund Processing: May charge fee or free

Payment Method Cost Variations:

- UPI: Typically 0% - 0.5% (lowest cost)
- Debit Cards: 0.4% - 1%
- Credit Cards: 1.5% - 2.5%
- Net Banking: 1% - 2%
- Wallets: 1% - 2%
- International Cards: 3% - 4%

RBI Regulations: Payment Aggregators

Master Direction on Payment Aggregators (September 15, 2025):

Categories:

- PA-Online (PA-O): Online payment aggregation
- PA-Physical (PA-P): Physical POS aggregation
- PA-Cross Border (PA-CB): Cross-border payment aggregation

Key Requirements:

- RBI Authorization: Mandatory registration/license
- Net Worth: Minimum capital requirements (₹15 crore for PA-O)
- Escrow Account: Customer funds held in escrow until settlement
- Merchant KYC: Conduct thorough KYC of all onboarded merchants
- Merchant Agreement: Written contract with clear terms
- Data Security: PCI-DSS, ISO 27001 certification
- Audits: Annual CERT-In audit, bi-annual VAPT
- Incident Reporting: Monthly reporting to RBI
- Prohibited Activities: Cannot operate marketplace in same entity, cannot set transaction limits (issuer/PSP prerogative)

Transition Timeline for PA-P:

- Apply by December 31, 2025
- Exit by February 28, 2026 if not applying

Reference:

- RBI Master Direction on Payment Aggregators, 2025
- Razorpay documentation:
- https://razorpay.com/docs/payments/

- https://www.linkedin.com/posts/sandeep-indurkar-138b6826_rbi-digitalpayments-paymentaggregators-activity-7373579145915797504
- https://sarafpartners.com/rbi-issues-the-reserve-bank-of-india-regulation-of-payment-aggregators-directions-2025/

4.4 Acquirer & Issuer Bank Roles

Acquirer Bank (Merchant Bank):

Definition: Financial institution that processes card payments on behalf of merchants and maintains merchant settlement accounts.

Key Responsibilities:

1. Merchant Onboarding
    - Conduct merchant KYC (business registration, tax IDs, bank details)
    - Assess merchant risk profile (business type, chargeback history)
    - Sign merchant service agreement
    - Assign Merchant ID (MID)
2. Authorization Request Processing
    - Receive authorization requests from payment gateway/merchant
    - Validate merchant credentials and transaction legitimacy
    - Forward to card network
3. Settlement
    - Receive funds from card network (batch settlements)
    - Deduct interchange fees, assessment fees, acquirer fees
    - Transfer net amount to merchant's settlement account
    - Typical settlement cycle: T+2 to T+7 days (varies by agreement)
4. Chargeback Management
    - Receive chargeback notifications from card network
    - Forward to merchant for evidence
    - Represent to card network if merchant contests
    - Debit merchant account if chargeback upheld
5. Fraud Monitoring
    - Monitor merchant transactions for suspicious patterns
    - Maintain fraud rate within card network thresholds (<1% for Visa/Mastercard)
    - May hold funds or terminate high-risk merchants
6. Compliance
    - Ensure merchant PCI-DSS compliance
    - Report suspicious merchant activity
    - Comply with card network rules

Issuer Bank (Customer's Bank):

Definition: Financial institution that issues payment cards to customers and maintains customer accounts.

Key Responsibilities:

1. Card Issuance
    - Issue credit cards, debit cards, prepaid cards to customers
    - Assign card numbers, CVV, PINs
    - Distribute cards securely
2. Customer Account Management
    - Maintain customer deposit/credit accounts
    - Set transaction limits (per-transaction, daily, monthly)
    - Manage available balance/credit limit
3. Authorization Decision
    - Receive authorization requests from card network
    - Perform comprehensive validation (covered in 4.2)
    - Approve/decline in real-time
    - Place authorization hold on approved transactions
4. Authentication
    - Operate Access Control Server (ACS) for 3D Secure
    - Send OTP to customer for CNP transactions
    - Validate customer credentials (PIN, OTP, biometric)
5. Settlement
    - Debit customer account for approved transactions
    - Receive settlement from card network
    - Reflect transactions in customer statement
6. Dispute Resolution
    - Receive customer dispute claims
    - Investigate transaction legitimacy
    - Initiate chargeback if warranted
    - Credit customer account pending resolution
7. Fraud Management
    - Real-time fraud detection on transactions
    - Block suspicious cards
    - Alert customers of potential fraud (SMS, app notifications)
    - Issue card replacement if compromised
8. Compliance
    - KYC/AML compliance for cardholders
    - Report suspicious transactions (STR/CTR)

- Adhere to RBI card issuance guidelines

Fund Flow: Acquirer ↔ Issuer

Authorization Phase:

```text
Customer → Merchant → Gateway → Acquirer Bank → Card Network → Issuer Bank
                                                                ↓
                                                        Authorization Hold
```

Clearing Phase:

```text
Issuer Bank → Card Network (batch settlement file at end of day)
```

Settlement Phase:

```text
Card Network → Acquirer Bank (net settlement T+1)
Acquirer Bank → Merchant (T+2 to T+7)

Card Network → Issuer Bank (reimbursement)
Issuer Bank → Customer Account (final debit)
```

Interchange Fees:

- Issuer bank earns interchange fee (portion of MDR)
- Paid by acquirer bank to issuer bank
- Compensates issuer for risks (fraud, credit risk) and costs (authorization infrastructure, customer service)
- Typical: 0.4% - 1% of transaction value (varies by card type, transaction type)

Assessment Fees:

- Card networks (Visa/Mastercard/RuPay) charge assessment fees
- Paid by both acquirer and issuer
- Revenue for card network for operating infrastructure

Reference:

- https://www.linkedin.com/posts/marcelvanoost_acquirer-issuer-the-different-authorization-activity-7258450778309152768-N_dl
- https://payu.in/blog/merchant-payment-gateway-types-and-benefits/
- Card network (Visa/Mastercard/RuPay) operating regulations

4.5 Settlement & Fund Transfer

Settlement Process Timeline:

Day T (Transaction Day):

- Customer makes payment
- Authorization approved
- Transaction recorded but not yet settled

Day T (End of Day):

- Clearing: Card network receives batch files from acquirers
- Consolidates all transactions
- Calculates net positions for each issuer and acquirer

Day T+1 (Settlement Day):

- Issuer Settlement: Card network debits/credits issuer banks' settlement accounts
- Acquirer Settlement: Card network debits/credits acquirer banks' settlement accounts
- Settlement via designated settlement bank (often central bank or large commercial bank)

Day T+2 to T+7 (Merchant Settlement):

- Acquirer bank transfers net amount to merchant's bank account
- Timeline varies by:
    - Merchant risk profile (new merchants may have longer holds)
    - Business type (high-risk businesses have delayed settlements)
    - Agreement terms
- Typical: T+2 for low-risk established merchants, T+7 for new/high-risk

---

Settlement Mechanisms:

1. Net Settlement (Most Card Transactions)

- At end of each day, card network calculates net position
- For Issuer: Total credits (customer purchases) minus total debits (refunds) = net payable
- For Acquirer: Total debits (merchant sales) minus total credits (refunds, chargebacks) = net receivable
- Settlement of net amount only (reduces number of fund transfers)

2. Gross Settlement (Some High-Value)

- Each transaction settled individually
- Used for specific high-value or real-time settlement requirements

---

Deductions from Settlement Amount:

Merchant Receives:

```text
Gross Transaction Amount
- Merchant Discount Rate (MDR) / Transaction Fee
- Chargebacks (if any)
- Refunds (if any)
- Gateway Service Fee
- GST on fees
= Net Settlement Amount to Merchant
```

Example Calculation:

```text
Gross Sales: ₹1,00,000
MDR @ 2%: - ₹2,000
Gateway Fee: - ₹500
GST @ 18% on fees: - ₹450
Chargebacks: - ₹5,000
Net Settlement: ₹92,050
```

Follow-ups

Key compliance steps for FinTechs under PSS Act 2007
RBI guidelines for UPI and digital wallet licensing
Changes in RBI KYC Master Directions 2025 vs 2016
RBI Payments Vision 2025 framework details
AML CFT requirements for digital payment providers